AUDITORÍA DE SEGURIDAD · WORDPRESS

Informe técnico de seguridad

http://127.0.0.1:8099

Cliente	Auditor	Fecha	Perfil
Empresa Demo S.A.S.	**Datos simulados**	**05/11/2026 14:09**	**quick**

CONFIDENCIAL

F

Riesgo crítico

Exposición grave; se requiere acción inmediata.

Índice de riesgo: 82/100. A mayor valor, mayor exposición.

1	3	4	11	1
Crítica	Alta	Media	Baja	Informativa

Evaluación parcial. No se evaluó por completo: Versiones (api.wordpress.org), Vulnerabilidades conocidas (CVE). Ver cobertura.

Hallazgos

Los críticos y altos aparecen abiertos. Filtra, busca y copia las correcciones.

Crítica WPA-001 **Copia de wp-config.php accesible públicamente**

Exposición de archivos · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Se puede descargar un respaldo del archivo de configuración con credenciales de base de datos y claves de seguridad.

IMPACTO

Compromiso total: acceso a la base de datos, posible toma de control del sitio y de los datos de usuarios.

EVIDENCIA

```
GET /wp-config.php.bak → HTTP 200 (61 bytes; contenido omitido por seguridad)
```

RECOMENDACIÓN

Retire el archivo del directorio web, rote TODAS las credenciales afectadas y revise los registros de acceso por descargas previas. Cambie las salts/keys de wp-config.php y la contraseña de la base de datos.

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/
- https://owasp.org/www-project-web-security-testing-guide/

Alta WPA-002 **Registro de depuración de WordPress accesible**

Exposición de archivos · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

debug.log es público y puede revelar rutas del servidor, consultas SQL, errores y datos de usuarios.

IMPACTO

Información valiosa para preparar ataques dirigidos.

EVIDENCIA

```
GET /wp-content/debug.log → HTTP 200 (74 bytes; contenido omitido por seguridad)
```

RECOMENDACIÓN

Elimine el archivo, desactive WP_DEBUG_LOG en producción o redirija el log fuera del directorio web.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
// wp-config.php (producción)
define('WP_DEBUG', false);
define('WP_DEBUG_DISPLAY', false);
define('WP_DEBUG_LOG', '/var/log/wordpress/debug.log');
```

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/
- https://owasp.org/www-project-web-security-testing-guide/

Alta WPA-003 **PHP 7.4 está fuera de soporte**

Plataforma · Esfuerzo medio · Fuente: wpaudit

DESCRIPCIÓN

Las ramas de PHP sin soporte no reciben parches de seguridad, aunque WordPress esté actualizado.

IMPACTO

Vulnerabilidades conocidas del lenguaje quedan sin corregir y pueden comprometer todo el servidor.

EVIDENCIA

```
Versión detectada: PHP/7.4.3
Fin de soporte de seguridad: 2022-11-28
```

RECOMENDACIÓN

Migre a una rama de PHP con soporte activo (consulte php.net/supported-versions) tras probar tema y plugins en un entorno de pruebas.

REFERENCIAS

- https://www.php.net/supported-versions.php

Alta WPA-004 **El sitio se sirve sin HTTPS**

Transporte · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

La URL auditada utiliza HTTP en claro. Credenciales, cookies de sesión y contenido viajan sin cifrar y pueden ser interceptados o alterados.

IMPACTO

Un atacante en la misma red (Wi-Fi público, proveedor) podría robar sesiones de administrador o inyectar contenido malicioso a sus visitantes.

EVIDENCIA

```
URL auditada: http://127.0.0.1:8099
```

RECOMENDACIÓN

Instale un certificado TLS (p. ej. Let's Encrypt), redirija todo el tráfico HTTP a HTTPS y actualice las URLs de WordPress (Ajustes → Generales) a https://.

REFERENCIAS

- https://owasp.org/www-project-web-security-testing-guide/
- https://letsencrypt.org/getting-started/

Media WPA-005 **Registro público de usuarios habilitado**

Autenticación · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Cualquier persona puede crear una cuenta. Si el rol por defecto no es 'Suscriptor' o hay plugins con fallos de escalada de privilegios, el riesgo aumenta.

EVIDENCIA

```
GET /wp-login.php?action=register → formulario de registro disponible
```

RECOMENDACIÓN

Desactive 'Cualquiera puede registrarse' (Ajustes → Generales) si no lo necesita; si lo necesita, mantenga el rol por defecto como Suscriptor y añada CAPTCHA/verificación de email.

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/

Media WPA-006 **Enumeración de nombres de usuario posible**

Autenticación · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Es posible obtener nombres de usuario válidos sin autenticarse (REST API y/o archivos de autor). Esto facilita los ataques de fuerza bruta y de credential stuffing.

IMPACTO

Los atacantes pueden dirigir ataques de contraseñas contra cuentas reales, incluidas las de administración.

EVIDENCIA

```
GET /wp-json/wp/v2/users → 2 usuario(s) listados sin autenticación
/?author=1 redirige a /author/admin/
Usuarios expuestos: admin, ana
```

RECOMENDACIÓN

Restrinja el endpoint /wp/v2/users a usuarios autenticados, bloquee ?author=N y use 2FA en cuentas con privilegios.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
// functions.php
add_filter('rest_endpoints', function ($e) {
  if (!is_user_logged_in()) {
    unset($e['/wp/v2/users'], $e['/wp/v2/users/(?P<id>[\d]+)']);
  }
  return $e;
});

# Apache: bloquear enumeración por ?author=
RewriteCond %{QUERY_STRING} (^|&)author=\d+ [NC]
RewriteRule ^ - [F]
```

REFERENCIAS

- https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/03-Identity_Management_Testing/04-Testing_for_Account_Enumeration_and_Guessable_User_Account

Media WPA-007 **Listado de directorios habilitado**

Configuración del servidor · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

El servidor muestra el contenido de directorios, revelando archivos que no deberían ser descubribles.

IMPACTO

Divulgación de ficheros internos, plugins instalados y posibles archivos sensibles subidos.

EVIDENCIA

```
GET /wp-content/uploads/ → HTTP 200 (119 bytes; contenido omitido por seguridad)
```

RECOMENDACIÓN

Desactive el autoindex en el servidor web.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
# Apache (.htaccess)
Options -Indexes

# Nginx
autoindex off;
```

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/
- https://owasp.org/www-project-web-security-testing-guide/

Media WPA-008 **XML-RPC habilitado con métodos de riesgo**

Superficie de ataque · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

xmlrpc.php permite probar cientos de contraseñas en una sola petición (system.multicall) y usar el sitio como pivote en ataques de denegación de servicio (pingback.ping).

IMPACTO

Facilita la fuerza bruta evadiendo límites de intentos de login y el abuso del servidor.

EVIDENCIA

```
POST /xmlrpc.php system.listMethods → 4 métodos
Método expuesto: system.multicall
Método expuesto: pingback.ping
```

RECOMENDACIÓN

Desactive XML-RPC si no usa Jetpack, la app móvil de WordPress o integraciones que lo requieran.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
// functions.php
add_filter('xmlrpc_enabled', '__return_false');

# Apache
<Files xmlrpc.php>
  Require all denied
</Files>

# Nginx
location = /xmlrpc.php { deny all; }
```

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/

Baja WPA-009 **Panel de acceso (wp-login.php) expuesto a Internet**

Autenticación · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

El formulario de login es accesible desde cualquier IP. Es el punto de entrada de la mayoría de ataques de fuerza bruta contra WordPress. No se detectó CAPTCHA.

IMPACTO

Intentos masivos de adivinar contraseñas; si prospera uno, el atacante controla el sitio.

RECOMENDACIÓN

Active 2FA para administradores/editores, limite intentos fallidos, use contraseñas únicas largas y, si es posible, restrinja /wp-admin por IP o detrás de VPN/WAF. (No se probaron contraseñas durante esta auditoría.)

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
# Apache — restringir wp-login por IP
<Files wp-login.php>
  Require ip 203.0.113.10
</Files>

# Nginx
location = /wp-login.php { allow 203.0.113.10; deny all; fastcgi_pass ...; }
```

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/

Baja WPA-010 **Existen nombres de usuario predecibles**

Autenticación · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Cuentas con nombres como 'admin' son el primer objetivo de ataques automatizados.

EVIDENCIA

```
Usuario: admin
```

RECOMENDACIÓN

Cree un administrador con nombre no predecible, reasigne el contenido y elimine la cuenta predecible.

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/

Baja WPA-011 **Cabeceras de seguridad HTTP recomendadas ausentes**

Cabeceras HTTP · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Las cabeceras de seguridad reducen el impacto de ataques como clickjacking, MIME sniffing, fuga de referrer y XSS. Faltan: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

IMPACTO

Menor defensa en profundidad frente a ataques en el navegador del visitante.

EVIDENCIA

```
Ausente: Content-Security-Policy
Ausente: X-Frame-Options
Ausente: X-Content-Type-Options
Ausente: Referrer-Policy
Ausente: Permissions-Policy
```

RECOMENDACIÓN

Añada las cabeceras ausentes en el servidor web. Para CSP, empiece en modo Content-Security-Policy-Report-Only y ajuste según los recursos de su tema/plugins.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
# Apache (.htaccess o vhost)
<IfModule mod_headers.c>
  Header always set Strict-Transport-Security "max-age=31536000;
includeSubDomains"
  Header always set X-Content-Type-Options "nosniff"
  Header always set X-Frame-Options "SAMEORIGIN"
  Header always set Referrer-Policy "strict-origin-when-cross-origin"
  Header always set Permissions-Policy "geolocation=(), microphone=(),
camera=()"
</IfModule>

# Nginx (bloque server)
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains"
always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "SAMEORIGIN" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=(), camera=()"
always;
```

REFERENCIAS

- https://owasp.org/www-project-secure-headers/
- https://developer.mozilla.org/docs/Web/HTTP/CSP

Baja WPA-012 **Scripts de terceros sin Subresource Integrity (SRI)**

Cadena de suministro · Esfuerzo medio · Fuente: wpaudit

DESCRIPCIÓN

Se cargan scripts externos sin verificación de integridad; si el proveedor se compromete, su sitio ejecutará código malicioso.

EVIDENCIA

```
cdn.example.net
```

RECOMENDACIÓN

Añada atributos integrity/crossorigin a scripts estáticos de terceros o aloje una copia propia.

REFERENCIAS

- https://developer.mozilla.org/docs/Web/Security/Subresource_Integrity

Baja WPA-013 **La REST API refleja el Origin y permite credenciales (comportamiento estándar de WordPress)**

Configuración del servidor · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

El endpoint /wp-json/ devuelve Access-Control-Allow-Origin igual al Origin recibido y Allow-Credentials: true. Es el comportamiento por defecto del núcleo de WordPress; las acciones autenticadas por cookie exigen además un nonce, por lo que no permite leer datos de un usuario desde otro sitio. Se informa como endurecimiento opcional.

EVIDENCIA

```
GET /wp-json/ con Origin: https://evil.example → ACAO: https://evil.example, ACAC: true
```

RECOMENDACIÓN

Si no usa la REST API desde otros dominios, restrinja los orígenes permitidos con el filtro rest_pre_serve_request o desde el servidor/CDN.

REFERENCIAS

- https://developer.wordpress.org/rest-api/

Baja WPA-014 **Métodos HTTP innecesarios habilitados**

Configuración del servidor · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

El servidor anuncia métodos que normalmente no se usan en un sitio web.

EVIDENCIA

```
Allow: GET,POST,OPTIONS,TRACE,PUT
```

RECOMENDACIÓN

Deshabilite métodos no necesarios (TRACE, PUT, DELETE, CONNECT).

REFERENCIAS

- https://owasp.org/www-project-web-security-testing-guide/

Baja WPA-015 **El servidor divulga versiones de software**

Divulgación de información · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Las cabeceras revelan tecnología y versiones exactas, facilitando la búsqueda de vulnerabilidades específicas.

EVIDENCIA

```
Server: Apache/2.4.29 (Ubuntu) Python/3.13.18
X-Powered-By: PHP/7.4.3
```

RECOMENDACIÓN

Oculte versiones: ServerTokens Prod / server_tokens off / expose_php = Off.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
# Apache
ServerTokens Prod
ServerSignature Off

# Nginx
server_tokens off;

# php.ini
expose_php = Off
```

REFERENCIAS

- https://owasp.org/www-project-web-security-testing-guide/

Baja WPA-016

Los readme.txt de los plugins son accesibles públicamente

Divulgación de información · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Los archivos readme.txt permiten a cualquiera conocer qué plugins y qué versiones exactas se usan.

EVIDENCIA

```
/wp-content/plugins/contact-form-7/readme.txt
```

RECOMENDACIÓN

Bloquee el acceso a readme.txt/changelog en wp-content/plugins desde el servidor web.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
# Nginx
location ~* ^/wp-content/plugins/.+/(readme|changelog)\.(txt|md)$ { deny all; }

# Apache
<FilesMatch "^(readme|changelog)\.(txt|md)$">
  Require all denied
</FilesMatch>
```

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/

Baja WPA-017

La versión de WordPress es visible públicamente

Divulgación de información · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Conocer la versión exacta permite a un atacante buscar exploits específicos. No es una vulnerabilidad por sí sola, pero facilita el reconocimiento.

EVIDENCIA

```
Meta generator en la portada: WordPress 5.0.3
/readme.html accesible (versión 5.0.3)
```

RECOMENDACIÓN

Elimine el meta generator, bloquee readme.html/license.txt y mantenga WordPress actualizado.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
// functions.php (o plugin de ajustes)
remove_action('wp_head', 'wp_generator');
add_filter('the_generator', '__return_empty_string');

# Apache: bloquear archivos informativos
<FilesMatch "^(readme\.html|license\.txt)$">
  Require all denied
</FilesMatch>
```

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/

Baja WPA-018 **Cookies sin atributos de seguridad**

Sesiones y cookies · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Algunas cookies no usan Secure, HttpOnly o SameSite, lo que facilita su robo o uso en ataques CSRF/XSS.

EVIDENCIA

```
Cookie 'sessid' sin: HttpOnly, SameSite
```

RECOMENDACIÓN

Configure los atributos en el servidor, plugin de caché o aplicación que emite la cookie.

REFERENCIAS

- https://owasp.org/www-project-web-security-testing-guide/

Baja WPA-019 **wp-cron.php accesible públicamente**

Superficie de ataque · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

Cada visita puede disparar wp-cron.php; llamarlo masivamente consume recursos (DoS de bajo costo).

EVIDENCIA

```
GET /wp-cron.php → HTTP 200
```

RECOMENDACIÓN

Desactive el cron por visita y programe una tarea real del sistema cada 5–15 minutos.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
// wp-config.php
define('DISABLE_WP_CRON', true);

# crontab
*/10 * * * * curl -s https://SU-SITIO/wp-cron.php?doing_wp_cron >/dev/null 2>&1
```

REFERENCIAS

- https://developer.wordpress.org/advanced-administration/security/hardening/

Informativa WPA-020 **No existe security.txt**

Gobernanza · Esfuerzo bajo · Fuente: wpaudit

DESCRIPCIÓN

No hay un canal publicado (RFC 9116) para que investigadores reporten vulnerabilidades de forma responsable.

RECOMENDACIÓN

Publique /.well-known/security.txt con un contacto de seguridad.

CORRECCIÓN SUGERIDA: ADÁPTALA Y PRUÉBALA ANTES DE PRODUCCIÓN

```
Contact: mailto:seguridad@su-dominio.com
Expires: 2027-12-31T23:59:59Z
Preferred-Languages: es, en
```

REFERENCIAS

- https://www.rfc-editor.org/rfc/rfc9116

Cobertura

Qué se pudo comprobar en esta ejecución. Lo no evaluado no significa que esté bien.

Área	Estado	Detalle
Versiones (api.wordpress.org)	**No evaluada**	Sin acceso a api.wordpress.org: verifique manualmente el núcleo, los plugins y los temas.
Vulnerabilidades conocidas (CVE)	**No evaluada**	Requiere WPScan con token: los plugins pueden tener fallos publicados que este informe no muestra.

Herramientas ejecutadas

Herramienta	Estado	Duración	Notas

Motor de wpaudit	ok	—	113 peticiones

Tecnología detectada

WordPress	5.0.3
PHP	7.4.3
Servidor	Apache/2.4.29 (Ubuntu) Python/3.13.18
Alojamiento	No identificado
CDN o WAF	No detectado
Usuarios expuestos	admin, ana
Hosts de terceros	cdn.example.net, insecure.example.org

Plugins

Plugin	Instalada	Última	Actualizado	Estado
contact-form-7	5.1	—	—	No verificado

Temas

Tema	Instalada	Última	Estado
twentytwenty	1.0	—	No verificado

HTTPS y TLS

No se analizó TLS porque el sitio no usa HTTPS o el puerto no fue accesible.

Cabeceras HTTP

Cabecera	Valor	Estado
Content-Security-Policy	—	Ausente
X-Frame-Options	—	Ausente
X-Content-Type-Options	—	Ausente
Referrer-Policy	—	Ausente

Permissions-Policy	—	**Ausente**

Metodología y límites

Objetivo	http://127.0.0.1:8099
Inicio y fin	2026-11-05 14:09:19 a 2026-11-05 14:09:48
Peticiones HTTP	113
Referencias	OWASP WSTG, OWASP Top 10, OWASP Secure Headers y guía de hardening de WordPress.

- No se hizo fuerza bruta ni se probaron límites de login: verifica 2FA, bloqueo de intentos y WAF manualmente.
- No se explotaron vulnerabilidades ni se inició sesión: no se evaluó el área de administración, los roles ni el código a medida.
- El inventario incluye los plugins visibles en el sitio, una lista corta de plugins comunes y los que encuentre WPScan: puede haber otros instalados. Sus versiones dependen de archivos públicos y pueden ser inexactas.